

Unit 4: E-Commerce Security and Fraud Issues and Protections

(Part-A)

Contents:

4.1 Basic EC Security Terminology, Threats, Attacks, and Attackers,

4.2 EC Security Requirements: Confidentiality, Integrity, and Availability, Authentication, Authorization and Nonrepudiation;

4.3 Technical Malware attack: Viruses, Worms, and Trojan Horses, Heartbleed, Distributed Denial of Service, Cryptolocker, Page hijacking, Botnets, Malvertising, ransomware, sniffing;

4.4 Non-Technical malware attack: Social Phishing, Pharming, Identity Theft and Identify Fraud, Spam Attacks;

4.1 Basic EC Security Terminologies

Security

- Information security, or information systems security, refers to a variety of activities and methods that protect information systems, data, and procedures from any action designed to destroy, modify, or degrade the systems and their operations.
- Computer security in general refers to the risks and protection of data, networks, computer programs, computer power, and other elements of computerized information systems.
- It is a very broad field due to the many methods of attack as well as the many modes of defense.
- The attacks on and defenses for computers can affect individuals, organizations, countries, or the entire Web.
- Computer security aims to prevent, repair, or at least minimize the attacks.
- E-commerce security is the protection of e-commerce assets from unauthorized access, use, alteration, or destruction.
- The security of data and information systems used in business is of utmost importance. Confidential business data and private customer and employee information must be safeguarded, and systems must be protected against malicious acts of theft or disruption.
- Although the need for security is obvious, it must often be balanced against other business needs. Business managers, IT professionals, and IT users all face a number of complex trade-offs when making decisions regarding IT security, such as the following:
 - i) How much effort and money should be spent to safeguard against computer crime? (In other words, how safe is safe enough?)
 - ii) What should be done if recommended computer security safeguards make conducting business more difficult for customers and employees, resulting in lost sales and increased costs?
 - iii) If a firm is a victim of a cybercrime, should it pursue prosecution of the criminals at all costs, maintain a low profile to avoid the negative publicity, inform affected customers, or take some other action?
- The number of cybercrimes being committed against individuals, organizations, and governments continues to grow, and the destructive impact of these crimes is also increasing.
- The brands, reputation, and earnings of many organizations around the world have been negatively impacted by such crimes. As a result, organizations are putting in place a range of countermeasures to combat cybercrime.

For instance, the worldwide financial services industry spent \$27.4 billion on IT security and fraud prevention in 2015. And a recent survey of more than 10,000 IT professionals around the world revealed the following:

- 58 percent of global companies have an overall security strategy
- 54 percent have a chief information security officer (CISO) in charge of security
- 53 percent have employee security awareness and training programs
- 52 percent have security standards for third parties
- 49 percent conduct threat assessments
- 48 percent actively monitor and analyze security intelligence

Why Computer Incidents Are So Widespread?

- *Increasing Complexity Increases Vulnerability:* Computing environments have become enormously complex. Cloud computing, networks, computers, mobile devices, virtualization, operating systems, applications, websites, switches, routers, and gateways are interconnected and driven by hundreds of millions of lines of code. The number of possible entry points to a network expands continually as more devices are added, increasing the possibility of security breaches.
- *Expanding and Changing Systems Introduce New Risks:* Business has moved from an era of stand-alone computers, to an era in which personal computers and mobile devices connect to networks with millions of other computers, all capable of sharing information. Businesses have moved quickly into e-commerce, mobile computing, collaborative work groups, global business, and inter-organizational information systems. However, it is increasingly difficult for IT organizations to keep up with the pace of technological change, successfully perform an ongoing assessment of new security risks, and implement approaches for dealing with them.
- *Increasing Popularity of BYOD Policies:* Bring your own device (BYOD) is a business policy that permits, and in some cases encourages, employees to use their own mobile devices (smartphones, tablets, or laptops) to access company computing resources and applications, including email, corporate databases, the corporate intranet, and the Internet. This practice raises many potential security issues as it is highly likely that such devices are also used for non-work activity (browsing websites, shopping, visiting social networks, blogging, etc.) that exposes them to malware much more frequently than a device used strictly for business purposes.
- *Growing Reliance on Commercial Software with Known Vulnerabilities:* In computing, an exploit is an attack on an information system that takes advantage of a particular system vulnerability. Often this attack is due to poor system design or implementation. Once the vulnerability is discovered, software developers create and issue a “fix,” or patch, to eliminate the problem. Users of the system or application are responsible for obtaining and installing the patch, which they can usually download from the web. Any delay in installing a patch exposes the user to a potential security breach.
- *Increasing Sophistication of Those Who Would Do Harm:* Previously, the stereotype of a computer troublemaker was that of an introverted “geek” working on his or her own and motivated by the desire to gain some degree of notoriety. This individual was armed with specialized, but limited, knowledge of computers and networks and use basic tools, perhaps downloaded from the Internet, to execute his or her exploits. While such individuals still exist, it is not this stereotyped individual who is the biggest threat to IT security.

Today’s computer threat is much better organized and may be part of an organized group such as:

- Anonymous
- Chaos Computer Club (Europe's largest association of hackers with 7700 registered members)
- Lizard Squad (black hat hacking group, mainly known for their claims of distributed denial-of-service attacks primarily to disrupt gaming-related services)
- TeslaTeam (TeslaTeam is currently the only virtual army in Serbia to openly launch cyber-attacks.)
- Hacker teams sponsored by national governments

These organized groups has an agenda and targets specific organizations and websites.

Some of these groups have ample resources, including fund and sophisticated tools to support their efforts. Today's computer attacker has greater depth of knowledge and expertise in getting around computer and network security safeguards.

Threat, attack and attacker

- A threat is anything potential to cause harm to the computer system or organization.
- A threat is a possible danger that might exploit a vulnerability to breach security and therefore cause possible harm.
- A threat can be either "intentional" or "accidental" or otherwise a circumstance, capability, action, or event.
- Unintentional threats fall into three major categories: human error, environmental hazards, and malfunctions in the computer system.
- In computers and computer networks an attack is any attempt to expose, alter, disable, destroy, steal or gain unauthorized access to or make unauthorized use of an asset.
- an attacker is the individual or organization performing these malicious activities.

Intentional Attacks and Crimes

Intentional attacks are committed by cybercriminals.

Types of intentional attacks include:

- theft of data,
- inappropriate use of data (e.g., changing it or presenting it for fraudulent purposes),
- theft of laptops and other devices and equipment, and/or inserting computer programs to steal data, vandalism or disruption directed toward the computer or its information system,
- damaging computer resources,
- losses from malware attacks, creating and distributing viruses, and
- causing monetary losses due to Internet fraud.

Intentional crimes carried out using computers and the Internet are called cybercrimes, which are done by cybercriminals (criminals for short) that include hackers and crackers.

Some of the criminals of computer crime (attackers) are:

- Black Hat Hacker: Someone who violates computer or Internet security maliciously or for illegal personal gain (in contrast to a white hat hacker who is someone who has been hired by an organization to test the security of its information systems).
- Cracker: An individual who causes problems, steals data, and corrupts systems.

- iii. Malicious Insider: An employee or contractor who attempts to gain financially and/or disrupt a company's information systems and business operations.
- iv. Industrial spy: An individual who captures trade secrets and attempts to gain an unfair competitive advantage.
- v. Cybercriminal: Someone who attacks a computer system or network for financial gain.
- vi. Hactivist: An individual who hacks computers or websites in an attempt to promote a political ideology.
- vii. Cyberterrorist: Someone who attempts to destroy the infrastructure components of governments, financial institutions, and other corporations, utilities, and emergency response units.

Some terms related to security:

Business continuity plan: A plan that keeps the business running after a disaster occurs. Each function in the business should have a valid recovery capability plan.

Cybercrime: Intentional crimes carried out on by using the Internet.

Cybercriminal: A person who intentionally carries out crimes over the Internet.

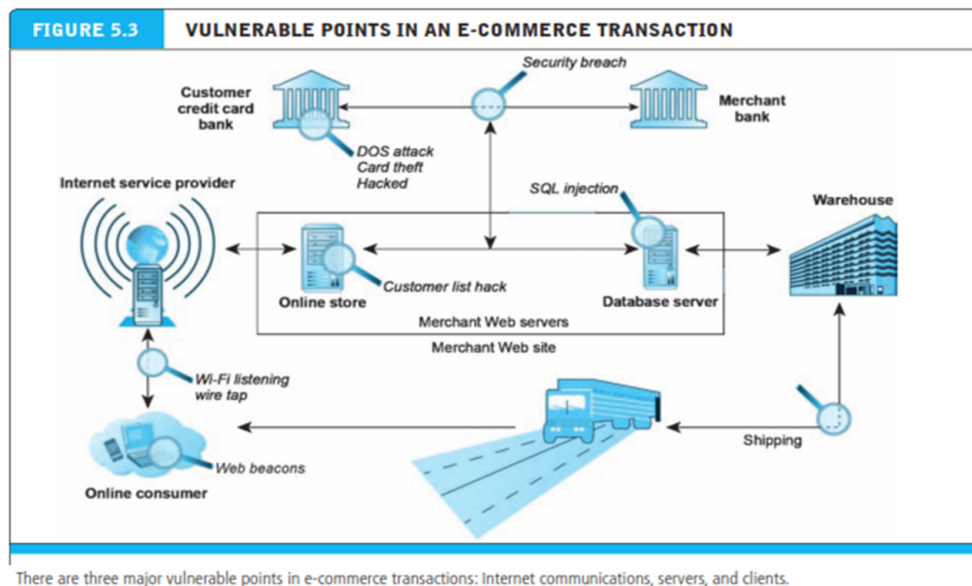
Exposure: An instance of being exposed to losses from an attack that exploits vulnerability (including estimate of damages).

Fraud: Any business activity that uses dishonest practices or devices to deprive others property or rights.

Vulnerability: Weakness or fault that can lead to an exposure.

Malware: malicious code such as viruses, worms, Trojan horses, bots, backdoors, spyware, adware, etc.

Cyber vandalism: Intentionally disrupting, defacing or destroying a Web site.





1 Major EC security management concerns

4.2 EC Security Requirements: Confidentiality, Integrity, and Availability (CIA)

The IT security practices of organizations worldwide are focused on ensuring:

- 1) Confidentiality,
- 2) Maintaining integrity, and
- 3) Guaranteeing the availability of systems and data.

Confidentiality ensures that only those individuals with the proper authority can access sensitive data such as employee personal data, customer and product sales data, and new product and advertising plans.

Integrity ensures that data can only be changed by authorized individuals so that the accuracy, consistency, and trustworthiness of data are guaranteed.

Availability ensures that the data can be accessed when and where needed, including during times of both normal and disaster recovery operations. A widely held but difficult-to-achieve standard of availability for a system or product is known as “five 9s” or 99.999 percent availability. For an operation that runs 365 days per year, 24 hours per day this translates to less than one hour of unavailability per year.

Confidentiality, integrity, and availability are referred to as the CIA security triad.

No organization can ever be completely secured from an attack. The key to prevention of a computer security incident is to implement a layered security solution to make computer break-ins so difficult that an attacker eventually gives up or is detected before much harm is inflicted. In a layered solution, if an attacker breaks through one layer of security, another layer must then be overcome. Security measures must be planned for, designed, implemented, tested, and maintained at the organization, network, application, and end-user levels to achieve true CIA security.

Authentication:

It is a process used to verify (assure) the real identity of an EC entity, which could be an individual, software agent, computer program, or EC website. For electronic messages, authentication verifies that the

sender/receiver of the message is who the person or organization claims to be (the ability to detect the identity of a person/entity with whom you are doing business)..

For many applications, users are required to enter a username and password to gain access. This is a form of single-factor authentication as the user needs to provide just one credential, a password to gain access.

Two-factor authentication requires the user to provide two types of credential before being able to access an account; the two credentials can be any of the following:

- Something you know, such as a PIN or password
- Something you have, such as some form of security card or token
- Something you are, such as a biometric (for example, a fingerprint or retina scan)

Two-factor authentication is required to withdraw money from a cash machine. You must present your bank card (something that you have) and a PIN (something that you know) to obtain cash from the machine.

Authorization:

It is the provision of permission to an authenticated person to access systems and perform certain operations in those specific systems.

Another important security mechanism is the creation of roles and user accounts so that once users are authenticated, they have the authority to perform their responsibilities and nothing more.

For example, members of the finance department should have different authorizations from members of the human resources department. An accountant should not be able to review the pay and attendance records of an employee, and a member of the human resources department should not know how much was spent to purchase an equipment. Even within one department, not all members should be given the same capabilities. Within the accounting department, for example, some users may be able to approve invoices for payment, but others may only be able to enter them.

Auditing:

When a person or program accesses a website or queries a database, various pieces of information are recorded or logged into a file. The process of maintaining or revisiting the sequence of events during the transaction, when and by whom, is known as auditing.

It is another important prevention tool in security. A security audit evaluates whether an organization has a well-considered security policy in place and if it is being followed.

For example, if a policy says that all users must change their passwords every 30 days, the audit must check how well that policy is being implemented.

The audit should also review who has access to particular systems and data and what level of authority each user has. One result of a good audit is a list of items that needs to be addressed. A thorough security audit should also test system safeguards to ensure that they are operating as intended. Such tests might include trying the default system passwords that are active when software is first received from the vendor. The goal of such a test is to ensure that all such known passwords have been changed.

Nonrepudiation:

It is closely associated with authentication, which is the assurance that online customers or trading partners will not be able to falsely deny (repudiate) their purchase, transaction, sale, or other obligation.

Nonrepudiation involves several assurances, including providing proof of delivery from the sender and proof of sender and recipient identities and the identity of the delivery company.

4.3 Technical Malware attack

Malware:

Malware (also called as Malicious software), is a threat to your devices and the cybersecurity. It's software that cyber attackers develop to gain access or cause damage to a computer or network, usually without the victim's knowledge.

Malware attack:

A malware attack is when cybercriminals create malicious software that's installed on someone else's device without their knowledge to gain access to personal information or to damage the device, usually for financial gain. Different types of malware include viruses, spyware, ransomware, and Trojan horses.

Types of malware attacks:

1. Technical malware attack
2. Non-technical malware attack

Technical Malware attack:

In this attack, attackers will try to deceive the user in believing that their victim is interacting with a real application or system and get them to provide confidential information and therefore allowing access to the organizational resources. Some of the common technical malware attacks are through: Viruses, Worms, and Trojan Horses, Heartbleed, Distributed Denial of Service, Cryptolocker, Page hijacking, Botnets, Malvertising, ransomware, sniffing.

Non-technical malware attack:

This attack is based on approach to perform purely through human trick i.e. by taking advantage of the victim's behavior weakness. Some of the common non-technical malware attacks are: Social Phishing, Pharming, Identity Theft and Identify Fraud, Spam Attacks.

Malware (Malicious Software): Viruses, Worms, and Trojan Horses:

Malware is a software program that, when spread, is designed to infect, alter, damage, delete, or replace data or an information system without the owner's knowledge or consent.

It is a comprehensive term that describes any malicious program or software (e.g., a virus is a "subset" of malware). Malware attacks are the most frequent security breaches. Computer systems infected by malware take orders from the criminals and do things such as send spam or steal the user's stored passwords.

Viruses

A virus is programmed software inserted by criminals into a computer to damage the system; running the infected host program activates the virus.

A virus has two basic capabilities: First, it has a mechanism by which it spreads. Second, it can carry out damaging activities once it is activated.

Antivirus software can be used to detect, delete or make the virus ineffective. The problem is that existing virus protection systems may not work against new viruses, and unfortunately, new viruses are created all the time.

A virus is a piece of programming code, usually disguised as something else that causes a computer to behave in an unexpected and usually undesirable manner.

For example, a virus may be programmed

- to display a certain message on an infected computer's display screen,
- delete or modify a certain document, or
- reformat the hard drive.

Almost all viruses are attached to a file, meaning the virus executes only when the infected file is opened. A virus is spread to other machines when a computer user shares an infected file or sends an email with a virus-infected attachment. In other words, viruses are spread by the action of the "infected" computer user.

Worms

Unlike a computer virus, which requires users to spread infected files to other users, a worm is a harmful program that resides in the active memory of the computer and duplicates itself. Worms differ from viruses in that they can propagate without human intervention, often sending copies of themselves to other computers by email.

A worm is capable of replicating itself on your computer so that it can potentially send out thousands of copies of itself to everyone in your email address book, for example.

The negative impact of a worm attack on an organization's computers can be considerable—

- lost data and programs,
- lost productivity due to workers being unable to use their computers,
- additional lost productivity as workers attempt to recover data and programs, and
- lots of effort for IT workers to clean up the mess and restore everything to as close to normal as possible.

The cost to repair the damage done by each of the Code Red, SirCam, and Melissa worms was estimated to exceed \$1 billion, with that of the Conficker, Storm, and ILOVEYOU worms totaling well over \$5 billion.

Trojan Horse

A Trojan horse is a program that seems to be harmless or even looks useful but actually contains a hidden malicious code. Users are tricked into executing an infected file, where it attacks the host, anywhere from inserting pop-up windows to damaging the host by deleting files, spreading malware, and so forth. e.g., Zeus, W32.

A Trojan horse often creates a "backdoor" on a computer that enables an attacker to gain future access to the system and compromise confidential or private information. A Trojan horse can be delivered via an email attachment, downloaded to a user's computer when he or she visits a website, or contracted via a removable media device, such as a DVD or USB memory stick. Once an unsuspecting user executes the program that hosts the Trojan horse, the malicious payload is automatically launched as well—with no significant signs. Common host programs include screen savers, greeting card systems, and games.

Another type of Trojan horse is a **logic bomb**, which executes when it is triggered by a specific event. For example, logic bombs can be triggered by a change in a particular file, by typing a specific series of keystrokes, or at a specific time or date.

Heartbleed

The Heartbleed Bug is a serious vulnerability in the popular OpenSSL cryptographic software library. This weakness allows stealing the information protected, under normal conditions, by the SSL/TLS encryption used to secure the Internet.

SSL/TLS provides communication security and privacy over the Internet for applications such as web, email, instant messaging (IM) and some virtual private networks (VPNs).

This bug allows anyone on the Internet to read the memory of the systems protected by the vulnerable versions of the OpenSSL software. This compromises the secret keys used to identify the service providers and to encrypt the traffic, the names and passwords of the users and the actual content. This allows attackers to eavesdrop on communications, steal data directly from the services and users and to impersonate services and users.



As long as the vulnerable version of OpenSSL is in use it can be abused. Fixed OpenSSL has been released to be deployed. Operating system vendors and distribution, appliance vendors, independent software vendors have to adopt the fix and notify their users. Service providers and users have to install the fix for the operating systems, networked appliances and software they use.

Distributed denial of service

A denial-of-service (DoS) attack is “a malicious attempt to make a server or network resource unavailable to users, usually by temporarily interrupting or suspending the services of a host connected to the Internet.”

This causes the system to crash or become unable to respond in time, so the site becomes unavailable. One of the most popular types of DoS attacks occurs when a hacker “floods” the system by overloading the system with “useless traffic” so a user is prevented from accessing their e-mail, websites, etc.

A DoS attack is a malicious attack caused by one computer and one Internet connection as opposed to a distributed denial-of-service (**DDoS**) attack, which involves many devices and multiple Internet connections.

For example, the attack on the Dyn on October 21, 2016 targeting DNS was done by thousands of computers taken hostage by the hackers. Dyn Inc. was an Internet performance management and web application security company, offering products to monitor, control, and optimize online infrastructure, and also domain registration services and email products. It is acquired by Oracle in 2017.

Starting October 21, 2016, Dyn was hit with a series of massive DDoS attacks. Millions of users on the East coast were unable to reach the websites of Dyn’s clients, including Airbnb, Amazon, Comcast, Etsy, GoFundMe, New York Times, PayPal, Shopify, and Twitter. The attack had a severe impact on the website owners, who were unable to provide customer services or generate e-commerce revenue.

CryptoLocker

The CryptoLocker ransomware attack was a cyberattack that occurred from 5 September 2013 to late May 2014. The attack utilized a trojan that targeted computers running Microsoft Windows. It propagated via different medium including infected email attachments.

When activated, the malware encrypted certain types of files stored on local and mounted network drives using RSA public-key cryptography, with the private key stored only on the malware's control servers. The malware then displayed a message which offered to decrypt the data if a payment (through either bitcoin or a pre-paid cash voucher) was made by a stated deadline, and it threatened to delete the private key if the deadline passes. If the deadline was not met, the malware offered to decrypt data via an online service provided by the malware's operators, for a significantly higher price in bitcoin. There was no guarantee that payment would release the encrypted content.

Although CryptoLocker itself was easily removed, the affected files remained encrypted in a way which researchers considered unfeasible to break. Many said that the ransom should not be paid, but did not offer any way to recover files; others said that paying the ransom was the only way to recover files that had not been backed up. Some victims claimed that paying the ransom did not always lead to the files being decrypted.

CryptoLocker was isolated in late May 2014 via Operation Tovar. During the operation, a security firm involved in the process obtained the database of private keys used by CryptoLocker, which was in turn used to build an online tool for recovering the keys and files without paying the ransom.

It is believed that the operators of CryptoLocker successfully extorted a total of around \$3 million from victims of the trojan.

Page hijacking or pagejacking

It is illegally copying website content so that a user can be misdirected to a different website. It is a common technique using which attackers compromise a legitimate website or create a duplicate of a popular website and take advantage of that to redirect traffic to a malicious website for malicious purposes.

Social media accounts are sometimes hijacked for the purpose of stealing the account holder's personal information.

For example, Justin Bieber's 50 million followers fell victim to this method when Bieber's Twitter account was hijacked in March 2014.

Page hijacking includes:

1. The various ways in which a user is secretly redirected to a different website. For example, **home page** hijacking refers to changing the default address of the home page in the user's browser. When the browser is launched, it goes to that Web page. **Browser hijacking** also refers to changing the home page as well as adding shortcuts to the Favorites menu or lowering security settings. These changes can be made using JavaScript or an ActiveX module.

Another form of page hijacking is copying a popular Web page from its original site to a third-party site so that it becomes indexed by search engines. After the links have been established, the content of the page is changed to reflect its real purpose, or it may redirect the user to a different site.

2. Stealing the source code of an attractive page from one site and using it on another with slight modifications.

Botnets

A botnet is a number of Internet-connected devices, each of which is running one or more bots. Botnets can be used to perform Distributed Denial-of-Service (DDoS) attacks, steal data, send spam, and allow the attacker to access the device and its connection.

A botnet is a logical collection of Internet-connected devices such as computers, smartphones or Internet of things (IoT) devices whose security have been breached and control ceded to a third party. Each compromised device, known as a "bot", is created when a device is penetrated by software from a malware distribution. The controller of a botnet is able to direct the activities of these compromised computers through communication channels formed by standards-based network protocols, such as IRC, Telnet, P2P and HTTP.

These infected computers (also called as zombie computer) then are used to perform unauthorized attacks over the Internet without the user's knowledge. Unauthorized tasks include sending spam and e-mail messages, attacking computers and servers, phishing and committing other kinds of fraud, causing the user's computer to slow down.

Each attacking computer is considered computer robot. The term botnet is derived from the terms roBOT and NETwork.

A bootnet called Necurs created 60,00,000 bots in 2014.

Protection from botnets:

1. Improve all user passwords for smart devices.
2. Avoid buying devices with weak security.
3. Update admin settings and passwords across all your devices.
4. Beware of any email attachments.
5. Never click links in any message you receive without verification.
6. Install effective anti-virus software.

Botnets are difficult to stop once they've taken root in user's devices. To reduce phishing attacks and other issues, be sure you guard each of your devices against this malicious hijack.

Malvertising

The term Malvertising is derived from the terms MALware and adVERTISING.

Malvertising is the use of online advertising to spread malware. It typically involves injecting malicious or malware-laden advertisements into legitimate online advertising networks and webpages.

It is accomplished by hiding malicious code within relatively safe online advertisements.

Note that hackers are targeting ads to hide malware at accelerating rates. For example, in 2013, Google disabled over 4 million ads from over sites that were hiding malware. This increased to 79 million in 2017.

Mobile Malvertising is growing rapidly along with the popularity of mobile computing devices.

If you get an e-mail that congratulates you on winning a large amount of money and asks you to "Please view the attachment," don't!

Malvertising vs adware

Malvertising is sometimes confused with adware. Malvertising refers to malicious code initially included in ads, which affects users who load an infected website. Adware is a program that runs on a user's computer. It's often installed hidden inside a package that also contains legitimate software, or lands on the machine without the knowledge of the user.

Avoiding Malvertising

- Using an updated antivirus
- Turning on click-to-play on the browser: All browsers allow you to select the "click-to-play" option. By selecting this, all online content that requires plugins to play — such as Java, Adobe Reader, QuickTime or Flash — will be disabled unless you manually give your OK for the content to play.
- Installing an ad blocker

Malvertising in present condition

The beginning of 2019 brought an increasing number of drive-by malicious ads that don't require a user's click. Currently, the most common attack is the gift card scam.

At the end of 2018, the company uncovered a massive malvertising campaign targeting iOS devices owned by U.S. citizens. The cybercriminal group known as ScamClub hijacked 300 million browser sessions in just two days.

Ransomware

Ransomware is a type of malware from cryptovirology that threatens to publish the victim's personal data or permanently block access to it unless a ransom is paid.

Attacker encrypt and lock digital files by using malware and demand a ransom before the system is unlocked it.

It is a growing threat, generating billions of dollars in payments to cybercriminals and inflicting significant damage and expenses for businesses and governmental organizations.

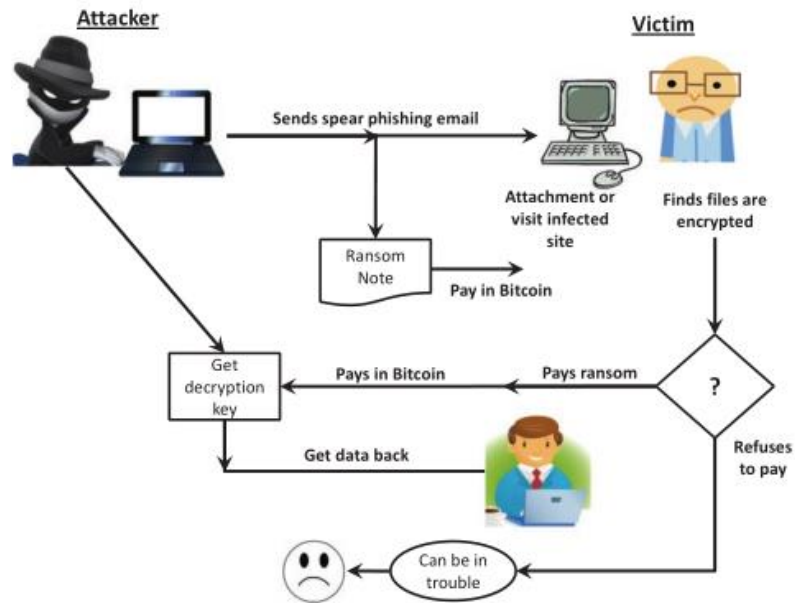
The most common ransomware infection routes include visiting malicious websites, downloading a malicious attachment or via unwanted add-ons during downloads. A single careless moment is enough to trigger to a ransomware attack. Since malware is designed to remain undetected for as long as possible, it is difficult to identify an infection. A ransomware attack is most likely to be detected by security software.

Changes to file extensions, increased CPU activity and other dubious activity may indicate an infection.

When removing ransomware, there are basically three options available:

- The first is to pay the ransom, which is definitely not recommended.
- It is therefore best to try to remove the ransomware from the computer.
- If this is not possible, only one step remains: reset your computer to factory settings.

Mobile ransomware is growing rapidly along with the popularity of mobile computing devices.



Forms of ransomware

There are two main categories of ransomware: locker ransomware and crypto ransomware.

Locker ransomware – basic computer functions are affected

Crypto ransomware – individual files are encrypted

The type of malware also makes a significant difference when it comes to identifying and dealing with the ransomware. Within the two main categories, distinctions are made between numerous additional types of ransomware. These include, for example, Locky, WannaCry, and Bad Rabbit.

One of the largest and most serious ransomware attacks took place in the spring of 2017 and was called WannaCry. In the course of the attack, approximately 200,000 victims from roughly 150 countries were asked to pay a ransom in Bitcoin.

Protection from ransomware

- i) Backup your data and secure them.
- ii) Use security software and keep it up to date.
- iii) Practice safe web surfing.
- iv) Use only secured networks.
- v) Stay informed about the latest threats, attacks and security technologies.
- vi) Implement a security awareness program.

Steps to respond to a ransomware attack

- i) Isolate the infected device and stop the spread.
- ii) Access the damages.
- iii) Locate patient zero: Tracking the infection becomes considerably easier once you've identified the source. To do so, check for any alerts that may have come from your antivirus/antimalware, or any active monitoring platform. And because most ransomware enters networks through malicious email links and attachments, which require an end user action, asking people about their activities (such as opening suspicious emails) and what they've noticed can be useful as well. Finally, taking a look at the properties of the files

themselves can also provide a clue—the person listed as the owner is likely the entry point. (Keep in mind, however, that there can be more than one Patient Zero!)

- iv) Identify the ransomware.
- v) Report the ransomware to authorities.
- vi) Evaluate your backups.
- vii) Research your decryption options.
- viii) Move on: Unfortunately, if you have no viable backups and cannot locate a decryption key, your only option may be to cut your losses and start from scratch.

Why shouldn't we just pay the ransom?

- i) We may never get a decryption key.
- ii) We could get repeated ransom demands.
- iii) We may receive a decryption key that may work some different task.
- iv) Even if everything somehow ends up fine, we're still funding criminal activity.

Sniffing

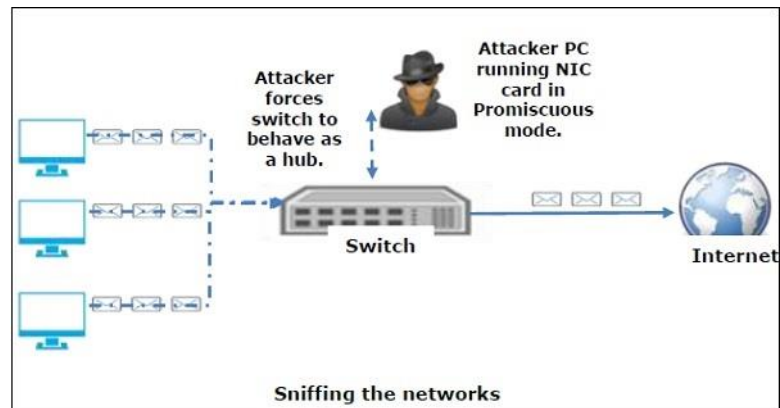
It is the process of monitoring and capturing all the packets passing through a given network using **sniffing** tools. It is a form of “tapping phone wires” and get to know about the conversation. It is also called wiretapping applied to the computer networks.

A **packet analyzer or packet sniffer** is a computer program or piece of computer hardware that can intercept and log traffic that passes over a digital network or part of a network. Packet capture is the process of intercepting and logging traffic.

Attackers use sniffers to capture data packets containing sensitive information such as password, account information etc.

Contents that can be sniffed

- Email traffic
- Passwords
- Web traffics
- Router configuration
- Chat sessions
- DNS traffic



Types of Sniffing

Sniffing can be either Active or Passive in nature.

1. In passive sniffing, the traffic is monitored, but it is not altered in any way. Passive sniffing allows listening only. It works with Hub devices. On a hub device, the traffic is sent to all the ports. In a network that uses hubs to connect systems, all hosts on the network can see the traffic. Therefore, an attacker can easily capture traffic going through.
The good news is that hubs are almost obsolete nowadays. Most modern networks use switches. Hence, passive sniffing is no more effective.
2. In active sniffing, the traffic is not only monitored, but it may also be altered in some way as determined by the attack. It is used to sniff a switch-based network. Some of the Active Sniffing Techniques – MAC Flooding, DHCP Attacks, DNS Poisoning, Spoofing Attacks, ARP Poisoning.

Hardware Protocol Analyzers

Hardware protocol analyzers is plugged into the network and can monitor traffic without manipulating it. It is used to monitor and identify malicious network traffic generated by hacking software installed in the system. It can capture a data packet, decode it, and analyze its content according to certain rules.

Hardware protocol analyzers allow attackers to see individual data bytes of each packet passing through the cable. These hardware devices are not readily available to most ethical hackers due to their enormous cost in many cases.

4.4 Non-Technical malware attack

Software and systems knowledge are used to perpetrate technical attacks. Insufficient use of antivirus and personal firewalls and unencrypted communication are the major reasons for technical vulnerabilities.

Nontechnical organizational attacks are those where the security of a network or the computer is compromised (e.g., lack of proper security awareness training). We consider financial fraud, spam, social engineering, that includes phishing, and other fraud methods, as nontechnical.

Many nontechnical methods also use some malware in their attacks. The goals of social engineering are to gain unauthorized access to systems or information by persuading unsuspected people to disclose personal information that is used by criminals to commit fraud and other crimes.

Social Engineering and Fraud

Social engineering refers to a collection of methods where criminals use human psychology to persuade or manipulate people into revealing their confidential information, or their employment information, so they can collect information for illegal activities.

The hacker may also attempt to get access to the user's computer in order to install malicious software that will give hackers control over the person's computer. Some of the social engineering attack techniques are: Baiting, Scareware, Pretexting, Phishing, and Spear phishing.

Baiting:

As its name implies, baiting attacks use a false promise to pique a victim's greed or curiosity. They lure users into a trap that steals their personal information or inflicts their systems with malware.

The most reviled form of baiting uses physical media to disperse malware. For example, attackers leave the bait—typically malware-infected flash drives—in conspicuous areas where potential victims are certain to see them (e.g., bathrooms, elevators, the parking lot of a targeted company). The bait has an authentic look to it, such as a label presenting it as the company's payroll list. Victims pick up the bait out of curiosity and insert it into a work or home computer, resulting in automatic malware installation on the system.

Baiting scams don't necessarily have to be carried out in the physical world. Online forms of baiting consist of enticing ads that lead to malicious sites or that encourage users to download a malware-infected application.

Scareware:

Scareware involves victims being bombarded with false alarms and fictitious threats. Users are deceived to think their system is infected with malware, prompting them to install software that has no real benefit

(other than for the perpetrator) or is malware itself. Scareware is also referred to as deception software, rogue scanner software and fraudware.

A common scareware example is the legitimate-looking popup banners appearing in your browser while surfing the web, displaying such text such as, "Your computer may be infected with harmful spyware programs." It either offers to install the tool (often malware-infected) for you, or will direct you to a malicious site where your computer becomes infected.

Scareware is also distributed via spam email that doles out bogus warnings, or makes offers for users to buy worthless/harmful services.

Pretexting:

Here an attacker obtains information through a series of cleverly crafted lies. The scam is often initiated by a perpetrator pretending to need sensitive information from a victim so as to perform a critical task.

The attacker usually starts by establishing trust with their victim by impersonating co-workers, police, bank and tax officials, or other persons who have right-to-know authority. The pretexter asks questions that are superficially required to confirm the victim's identity, through which they gather important personal data.

All sorts of pertinent information and records is gathered using this scam, such as social security numbers, personal addresses and phone numbers, phone records, staff vacation dates, bank records and even security information related to a physical devices.

Phishing:

It is a dishonest process of acquiring confidential information, such as credit card or banking details, from unsuspecting computer users.

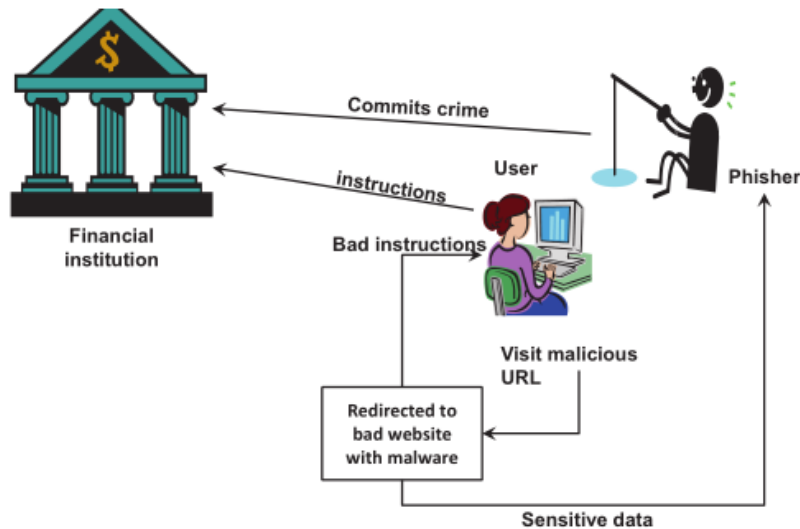
A phisher sends an e-mail, IM, comment, or text message that appears to come from a legitimate, well-known, popular company, bank, school, or public institution.

The user is instructed to enter a corrupted website, where he or she may be tricked into submitting confidential information (e.g., being asked to "update" information). Sometimes phishers install malware to facilitate the extraction of information.

Spear phishing:

This is a more targeted version of the phishing scam whereby an attacker chooses specific individuals or enterprises. They then tailor their messages based on characteristics, job positions, and contacts belonging to their victims to make their attack less conspicuous. Spear phishing requires much more effort on behalf of the perpetrator and may take weeks and months to pull off. They're much harder to detect and have better success rates if done skillfully.

A spear phishing scenario might involve an attacker who, in impersonating an organization's IT consultant, sends an email to one or more employees. It's worded and signed exactly as the consultant normally does, thereby deceiving recipients into thinking it's an authentic message. The message prompts recipients to change their password and provides them with a link that redirects them to a malicious page where the attacker now captures their credentials.



Pharming

Pharming is a form of online fraud involving malicious code and fraudulent websites. Cybercriminals install malicious code on your computer or server. The code automatically directs you to bogus websites without your knowledge or consent.

The goal is to get you to provide personal information, like payment card data or passwords, on the false websites. Cybercriminals could then use your personal information to commit financial fraud and identity theft.

Pharming combines the words “phishing” and “farming.” This cybercrime is also known as “phishing without a lure.”

Phishing is an online fraud scheme where a cybercriminal hopes you’ll click on a compromised email link which takes you to a fake site where you then enter your access credentials — such as your username and password. If you do, the fraudster can then access the real site and steal your personal information there.

Pharming, on the other hand, is a two-step process. One, cybercriminals install malicious code on your computer or server. Two, the code sends you to a bogus website, where you may be tricked in providing personal information. Computer pharming doesn’t require that initial click to take you to a fraudulent website. Instead, you’re redirected there automatically. The fraudster has immediate access to any personal information you enter on the site..

Types:

- i) **Malware-based pharming:** In this form of pharming, malicious code sent in an email can change your computer’s local host files. These corrupted host files can then direct your computer to fraudulent sites regardless of the Internet address you type.
- ii) **DNS Server poisoning:** This pharming scam doesn’t rely on corrupting individual files, but rather occurs at the DNS server level by exploiting a vulnerability. The DNS table is essentially poisoned, so you’re being redirected to fraudulent websites without your knowledge. If a large DNS server is corrupted, cybercriminals could target and scam an even larger group of victims.

Anti-pharming safeguards:

- Install and use updated antivirus.
- Ensure you are using secure web connections (look for https in the web address)
- Be cautious when opening links or attachments that you weren't expecting or that are from an unfamiliar sender
- Avoid suspicious websites
- Enable two-factor authentication on sites that offer it
- Use a reputable internet service provider, whenever possible
- Use a VPN service that has reputable DNS servers
- Change the default password on your consumer-grade routers and wireless access points

Example 1: An example of a sophisticated pharming attack occurred in 2017, when more than 50 financial institutions found themselves to be the recipients of a pharming attack that exploited a Microsoft vulnerability, creating fraudulent websites that mimicked the bank sites targeted.

The victims — online customers in the United States, Europe and Asia-Pacific — were lured to a website with malicious code that then downloaded a Trojan along with five files from a Russian server.

When these customers visited the fake sites from their infected computers, their account login information was sent to the Russian servers. This pharming attack infected approximately 3,000 PCs in a three-day period.

As these cyberattacks show, pharming could be a major threat for people using e-commerce and online banking websites.

Example 2: In 2019, a notable pharming attack took place in Venezuela. That year, Venezuela's President made a public call asking for volunteers to join a new movement called "Voluntarios por Venezuela" (Volunteers for Venezuela). The purpose of this movement was to connect volunteers with international organizations providing humanitarian aid to the country. Volunteers were invited to sign up via a website that asked for their full name, personal ID, phone number, location, and other personal details.

Within a week of the original website going live, a second website appeared. This was almost identical, with a similar domain name and structure. However, it was a fake. Within Venezuela, both the real and counterfeit websites resolved to the same IP address, which belonged to the fake domain owner. This meant that regardless of whether a user opened the real or fake website, ultimately, their data would end up at the fake one. (Outside the country, they resolved to a different IP address.)

Identity theft and Identity fraud

Identity theft is the criminal act of stealing personal, private, or financial information with the intent of using it to assume another person's identity.

Most often, the stolen identity is used to make fraudulent purchases or to open credit card and bank accounts. Additionally, a fake identity can impact healthcare claims, taxes, and even criminal records.

Identity theft can happen in many different ways.

- In some cases, a stolen wallet is all it takes. With this, thieves usually have access to your ID, credit cards, bank cards, and more.
- A lost smartphone also provides criminals with a variety of personal information to use.
- Using social engineering attacks like phishing, using malwares.

- Other methods include home robbery, computer hacking, and unsafe internet connections or online transactions.

Protecting your personal information is the best way to protect yourself from identity theft.

Identity theft is the act of stealing personal, private, or financial information whereas **identity fraud** is the use of this stolen information. This crime affects both the individuals whose identity has been stolen and the businesses where the stolen identity has been used to make fraudulent transactions.

Additionally, the fake identity used doesn't necessarily have to be that of someone living, or even real. Thieves often assume the identity of the deceased or create fake identities of people who never existed to commit a crime.

Identity fraud also includes to assuming the identity of another person or creating a fictitious person and then unlawfully using that identity to commit a crime. Typical activities include:

- Credit card fraud
- Making a purchase using a false identity (e.g., using another's identity to buy goods)
- Business identity theft is using another's business name to obtain credit or to get into a partnership
- Posing as another to commit a crime
- Conducting money laundering (e.g., organized crime) using a fake identity
- Employment or tax-related fraud
- Phone or utilities fraud
- Bank fraud
- Loan or lease fraud
- Government documents or benefits fraud

Spam Attacks:

Email spam is the use of email systems to send unsolicited email to large numbers of people. Most spam is a form of low-cost commercial advertising, sometimes for questionable products such as pornography, phony get-rich-quick schemes, and worthless stock. Spam is also an extremely inexpensive marketing tool used by many legitimate organizations.

For example, a company might send email to a broad cross section of potential customers to announce the release of a new product in an attempt to increase initial sales. However, spam is also used to deliver harmful worms and other malware.

In early 2015, Symantec, a provider of security, storage, and systems management solutions, began noticing multiple instances of short-duration, high-volume spam attacks targeting millions of users. The messages instructed recipients to click on a link to a URL, which, if done, resulted in the Trojan Infostealer.Dyranges(Dyre)" being downloaded to their computer. This Trojan is known to steal financial information.

The Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act in US states that it is legal to spam, provided the messages meet a few basic requirements—spammers cannot disguise their identity by using a false return address, the email must include a label specifying that it is an ad or a solicitation, and the email must include a way for recipients to indicate that they do not want future mass mailings.

Many companies—including Google, Microsoft, and Yahoo!—offer free email services. Spammers often seek to use email accounts from such major, free, and reputable web-based email service providers, as

their spam can be sent at no charge and is less likely to be blocked. Spammers can defeat the registration process of the free email services by launching a coordinated bot attack that can sign up for thousands of email accounts. These accounts are then used by the spammers to send thousands of untraceable email messages for free. A partial solution to this problem is the use of CAPTCHA to ensure that only humans obtain free accounts. CAPTCHA (Completely Automated Public Turing Test to Tell Computers and Humans Apart) software generates and grades tests that humans can pass and all but the most sophisticated computer programs cannot. For example, humans can read the distorted text but simple computer programs cannot.

Spyware:

Spyware is a tracking software that is installed by criminals, without the user's consent, in order to gather information about the user and direct it to advertisers or other third parties.

Once installed the spyware program tracks and records the user's movements on the Internet. Spyware may contain malicious code redirecting Web browser activity.

Spyware can also slow surfing speeds and damage a program's functionality. Spyware usually is installed when you download freeware or shareware.

Practice Question:

1. How you define network security?
2. Explain the Network security goal with example.
3. Differentiate between authorization and authentication.
4. What is DDOS attack?
5. Explain the working mechanism of Anti-virus software.
6. What is technical attack? Explain five technical attack on EC Application.
7. What is ransomware? Explain defense technic of ransomware.
8. Define availability, authentication and authorization. How they can be enforced in e-commerce security? [TU-BCA-2020]